

SECURITY ENGINEER INTRO

[Kaynak](#)

İÇERİK

1. Organizasyonlar Neden Güvenliğe İhtiyaç Duyar?
2. Güvenlik Mühendisinin Rolü ve Sorumlulukları
3. Bir Güvenlik Mühendisinde Aranılan Nitelikler
4. Güvenlik Mühendisinin Temel Sorumluluk Alanları
5. Sürekli İyileştirme
6. Ek Roller ve Sorumluluklar

Kurumsal Güvenlik İhtiyacı ve Güvenlik Mühendisliği

1. Organizasyonlar Neden Güvenliğe İhtiyaç Duyar?

İnternet çağının küresel çapta iş yapış biçimlerini dönüştürmesi, organizasyonlar için hem büyük fırsatlar hem de ciddi zorluklar doğurmuştur. Teknoloji; inovasyon ve iş birliği süreçlerini kolaylaştırır da beraberinde ciddi siber riskleri getirmiştir.

- **Dijital Tehditlerin Doğası:** Günümüzde organizasyonlar; sistemlerin hacklenmesi, müşteri verilerinin sızıntıya uğraması ve **fidye yazılımı (ransomware)** saldırıları gibi tehditlerle sürekli karşı karşıyadır.
- **Stratejik Tercih Zorunluluğu:** Tehditler karşısında kurumların önünde iki yol bulunmaktadır:
 1. Teknolojik imkanlardan feragat ederek eski yöntemlere dönmek (Bu durum kurumu rekabet avantajından mahrum bırakır).
 2. Dijital süreçleri modernize ederken bu süreçlerin güvenliğini en üst düzeyde sağlamak.
- **Varlıkların Korunması:** Bir kurumun fiziksel varlıklarını koruması ve bunun için özel departmanlar kurması ne kadar doğalsa, **dijital varlıkların** korunması da aynı derecede zorunludur.
- **Temel Amaç:** Güvenlik önlemlerinin nihai hedefi, organizasyonun birincil hedeflerine ve operasyonlarına herhangi bir engel veya kesinti olmaksızın ulaşmasını sağlamaktır.

2. Güvenlik Mühendisinin Rolü ve Sorumlulukları

Organizasyonlar, siber riskleri yönetmek ve dijital varlıklarını koruma altına almak amacıyla **Güvenlik Mühendisi** pozisyonuna ihtiyaç duyarlar. Kurumsal perspektifte bir güvenlik mühendisinin temel fonksiyonları şunlardır:

- **Uçtan Uca Güvenlik Sahipliği:** Organizasyonun genel güvenliğinden ve dijital varlıkların korunmasından sorumlu olan ana kişidir.
- **Risk Minimizasyonu:** Kurumun siber güvenlik risklerinin her an en düşük seviyede tutulmasını sağlar.
- **Strateji ve Sistem Geliştirme:** Siber tehditlerin oluşturduğu riskleri azaltmaya yönelik stratejiler geliştirir ve bu stratejileri destekleyen teknik sistemler kurar.
- **Periyodik Test ve Denetim:** Kurumun siber güvenlik duruşunun (posture) sağlamlığını ölçmek için düzenli testler yapar; zayıf noktaları tespit ederek uygun **iyileştirme (mitigation)** planlarını hazırlar.
- **Güvenli Ağ Çözümleri:** Ağ altyapıları için güvenli çözümler geliştirir ve bunları uygulamaya koyar.
- **Güvenilir Sistem Mimarisi:** Güvenilir, dayanıklı ve emniyetli sistemlerin mimarisini tasarlar ve mühendisliğini yapar.
- **Koordinasyon ve Protokol Oluşturma:** Kurum genelinde güvenlik protokollerinin yerleşmesi için diğer tüm ekiplerle iş birliği ve koordinasyon sağlar.

3. Bir Güvenlik Mühendisinde Aranılan Nitelikler

Güvenlik mühendisliği rolü oldukça geniş bir kapsama sahiptir ve organizasyondan organizasyona farklılık gösterebilir. Bazı durumlarda bu görevlerin tamamı tek bir kişi yerine koca bir departman tarafından yürütülür.

3.1. Mühendislik Yaklaşımı

Güvenlik mühendisi, klasik bir mühendislik mantığıyla hareket eder: **Büyük ve karmaşık problemleri alır, bunları yönetilebilir küçük parçalara böler ve her bir parça için çözüm üretir.** Bu nedenle, sabit bir iş tanımı olsa bile, her gün karşılaşılan problemlerin değişkenliği nedeniyle işin doğası oldukça dinamiktir.

3.2. Temel Gereksinimler ve Yetkinlikler

Organizasyonlar, bir güvenlik mühendisini işe alırken genellikle şu temel nitelikleri gözetir:

- **Deneyim:** Bilgi Teknolojileri (BT) yönetimi, helpdesk (yardım masası), ağ yönetimi veya güvenlik operasyonları alanlarında **0-2 yıl arası tecrübe.**
- **Teknik Temel:** Bilgisayar ağları, işletim sistemleri ve programlama konularında temel düzeyde yetkinlik.
- **Güvenlik Kavramları:** Güvenlik stratejilerinin temelini oluşturan **Yönetişim, Risk ve Uyum (GRC - Governance, Risk and Compliance)** gibi kavramlar hakkında teorik ve pratik anlayış.

4. Güvenlik Mühendisinin Temel Sorumluluk Alanları

Bir güvenlik mühendisinin genel sorumlulukları, organizasyonun hedeflerine ulaşmasını sağlamak amacıyla geniş bir yelpazeye yayılır. Bu sorumluluklar şu ana başlıklar altında

toplanır:

4.1. Varlık Yönetimi ve Varlık Envanteri (Asset Management)

Organizasyon güvenliğini sağlamanın ilk ve en kritik adımı, neyin korunduğunu tam olarak bilmektir.

- **Dijital Envanter Yönetimi:** Mühendis, kurumun tüm dijital varlıklarının listesini tutmak ve yönetmekle yükümlüdür. Bilinmeyen bir varlık (shadow IT), korunamayan bir varlıktır.
- **Envanter Detayları:** Düzenli olarak güncellenen bu envanter; varlık adı, türü, **IP adresleri**, fiziksel konumu, ağdaki konumu, üzerinde çalışan uygulamalar, **erişim izinleri** (dahili veya halka açık) ve varlık sahibi detaylarını içermelidir.
- **Sahiplik:** Güvenlik mühendisi, ancak kurumun sahip olduğu tüm varlıkları bildiği takdirde güvenliğin gerçek "sahibi" olabilir.

4.2. Güvenlik Politikaları (Security Policies)

Sağlam bir güvenlik duruşu, kurumsal kuralların ve standartların belirlenmesine bağlıdır.

- **Politika Oluşturma:** Mühendis, yerleşik **Güvenlik İlkeleri (Security Principles)** temelinde kurumsal güvenlik politikalarının oluşturulmasına yardımcı olur.
- **Uygulama ve Denetim:** Bu politikaların organizasyon genelinde hem lafzına hem de ruhuna uygun şekilde uygulanmasını sağlar.
- **İstisna Yönetimi:** İş gereksinimleri nedeniyle bazen politikalardan sapılması gerekebilir. Bu durumda mühendis; güvenlik ilkelerine danışarak istisnayı onaylar veya reddeder. Eğer istisna onaylanırsa, riski minimize etmek için ek **iyileştirme (mitigation)** adımları önerir.

4.3. Tasarım Gereği Güvenlik (Secure by Design)

Güvenliğin sonradan eklenen bir katman değil, sistemin temeline entegre bir felsefe olması gerekir. Mühendis, bu yaklaşımın en yüksek **Yatırım Getirisini (ROI)** sağladığını bilir.

- **Güvenli Ağ Mimarisi:** Ağ yapısının en baştan sızmalara karşı dirençli tasarlanmasını sağlar.
- **Sistem Sıkılaştırma (Hardening):** Kurum bünyesindeki **Windows**, **Linux** ve **Active Directory** yapılarının güvenlik açıklarına karşı yapılandırılmasını ve "sıkılaştırılmasını" sağlar.
- **Güvenli Yazılım Geliştirme:** Yazılım süreçlerinin **Güvenli Yazılım Geliştirme Yaşam Döngüsü (S-SDLC)** kurallarına uygun ilerlemesini denetler.

4.4. Güvenlik Değerlendirmesi ve Güvence (Assessment & Assurance)

Güvenlik bir varış noktası değil, sürekli bir çabadır. Bir saldırganın başarılı olması için tek bir açık (loophole) yeterliyken, mühendisin her şeyi doğru yapması gerekir.

- **Sürekli İyileştirme:** Gelişen tehdit ekosistemine karşı düzenli güvenlik değerlendirmeleri ve denetimler planlar.
- **Egzersizler ve Testler:** Kurumun savunma kapasitesini ölçmek için **Red-Teaming** (saldırı simülasyonu) ve **Purple-Teaming** (savunma ve saldırı ekiplerinin koordinasyonu) egzersizlerini organize eder.
- **Süreç Yönetimi:** Mühendis bu testleri bizzat gerçekleştirmese bile; faaliyet takviminin oluşturulması, dış tedarikçiler için **Teklif İsteme Belgesi (RFQ)** hazırlanması ve test sonuçlarından çıkan bulguların önceliklendirilerek düzeltilmesi süreçlerini yönetir.

5. Sürekli İyileştirme (Continuous Improvement)

Organizasyon güvenliği tek seferlik bir proje değil, sürekli devam eden bir çabadır. Güvenlik politikaları tasarlanıp uygulandıktan sonra mühendisin işi bitmez; aksine sürekli iyileştirme yolculuğu başlar.

5.1. Farkındalığın Sağlanması (Ensuring Awareness)

İnsan faktörü, herhangi bir organizasyonun temel yapı taşıdır, ancak güvenlik dünyasında sıklıkla dile getirildiği gibi "**en zayıf halka**"dır. Güvenlik mühendisi, organizasyonda belirli bir farkındalık seviyesini korumakla yükümlüdür.

- **Genel Farkındalık:** İnsanların hata yaparak organizasyon güvenliğini tehlikeye atmasını önlemek amacıyla, özellikle **Sosyal Mühendislik (Social Engineering)** saldırılarını hedef alan periyodik eğitim oturumları düzenlenir.
- **Uzmanlık Bazlı Eğitimler:** Sadece genel personel için değil, teknik ekipler için de kendi uzmanlık alanlarına yönelik (örneğin; yazılımcılar için **Güvenli Yazılım Geliştirme**, ağ ekipleri için **Güvenli Ağ Mimarisi**) özel oturumlar organize edilir.

5.2. Risk Yönetimi (Managing Risks)

Üst yönetim, güvenliğe genellikle "riskleri minimize etme" merceğinden bakar. Güvenliğin ihmal edilmesi; operasyonel kesintiler, veri sızıntıları ve yasal davalar gibi ciddi sonuçlar doğurabilir.

- **Süreç:** Güvenlik mühendisi riskleri tanımlar, olasılıklarını ve etkilerini belirler ve bunları minimize edecek çözümler üretir.
- **Güvenilir Danışman Rolü:** İş operasyonlarını yürütürken tüm riskleri ortadan kaldırmak her zaman mümkün değildir. Bazen bir riski "kabul etme" kararı alınması gerekir. Mühendis, yönetime konu uzmanlığı sağlayarak bu kararların alınmasında **güvenilir bir danışman (trusted advisor)** rolü üstlenir.
- **Vaka Analizi: Tedarik Zinciri Yazılımı ve Linux Senaryosu**
 - **Durum:** Bir organizasyonun tedarik zinciri operasyonları için kritik öneme sahip bir veritabanı yazılımı kullandığını varsayalım. Bu yazılım, **Linux** işletim sisteminin savunmasız (vulnerable) eski bir sürümü üzerinde çalışmaktadır.

- **Sorun:** Yazılımı, savunmasız olmayan en son **İşletim Sistemi (OS)** sürümünde çalışacak şekilde güncellemek, satıcı (vendor) henüz test etmediği için bir yıldan fazla sürecek ciddi bir efor gerektirmektedir. Test edilmeden yapılacak bir güncelleme, operasyonları durdurma riski taşır.
- **Çözüm (Mitigation):** Bu senaryoda güvenlik mühendisi riski kabul etmek yerine "hafifletme" yoluna gider.
 1. İşletim sistemi ek kontrollerle **sıkılaştırılır (hardening)**.
 2. Sistemin doğrudan internete açılmasını önlemek için önüne bir **Ters Vekil Sunucusu (Reverse Proxy)** eklenir.
- **Sonuç:** Bu adımlar riski tamamen ortadan kaldırmasa da, operasyonları aksatmadan riski önemli ölçüde azaltır.

5.3. Değişim Yönetimi (Change Management)

Organizasyonlar zamanla evrimleşir ve bu değişimler güvenlik duruşunu etkiler. Güvenlik mühendisi, dijital varlıklardaki değişimleri takip ederek güvenliğin bu evrime ayak uydurmasını sağlar.

- **Vaka Analizi: E-Ticaret Modülü Yükseltmesi**
 - **Durum:** Bir organizasyon, kurumsal müşterileri için web sitesindeki e-ticaret modülünü yükseltmek istemektedir.
 - **Gereksinimler:** Yeni modül siteye entegre edilmeden önce; **Risk Değerlendirmesi, Sızma Testi (Penetration Testing)** ve **Zafiyet Değerlendirmesi (Vulnerability Assessment)** yapılmalıdır.
 - **Mühendisin Rolü:** Güvenlik mühendisi, entegrasyonun yeni güvenlik açıkları yaratmamasını ve organizasyonun belirlediği tüm güvenlik politikalarına uyulmasını garanti altına alır.

5.4. Zafiyet Yönetimi (Vulnerability Management)

Tehdit ortamı sürekli değişmektedir; yeni yazılım sürümleri yayınlanır ve eski sürümlerde zafiyetler bulunur.

- **İzleme ve Yamama:** Güvenlik mühendisi, organizasyon genelindeki zafiyetleri izler ve bunların riskini azaltmak için yama (patch) planlaması yapar.
- **Önceliklendirme:** Zafiyetler rastgele değil, önem derecesine (severity) göre önceliklendirilerek yamalanır.

5.5. Uyumluluk ve Denetimler (Compliance and Audits)

Güvenlik mühendisinin görevlerinin önemli bir kısmı, yasal ve kurumsal gerekliliklere uyumu sağlamaktır.

- **Standartlar:** Organizasyonun sektörü, müşteri kitlesi ve bulunduğu konuma göre **PCI-DSS, HIPAA, SOC2, ISO27001, NIST-800-53** gibi çeşitli standartlara tabi olabilir.

- **Denetim Süreci:** Mühendis, hem iç hem de dış denetçilerle (auditors) yakın çalışarak uyumsuzluk sorunlarını tespit eder ve giderir. Ayrıca gerekli güvenlik sertifikalarının sürdürülmesinden sorumludur.

6. Ek Roller ve Sorumluluklar

Daha önce belirtildiği üzere, güvenlik mühendisliği rolü genellikle geniş kapsamlıdır ve sınırları esnek olabilir. Bazı organizasyonlarda güvenlik mühendisi, diğer ekiplere yardımcı olmak veya operasyonel boşlukları doldurmak adına aşağıdaki ek sorumlulukları üstlenir.

6.1. Güvenlik Araçlarının Yönetimi (Managing Security Tooling)

Bazı durumlarda bir güvenlik mühendisinin teknik araçlara doğrudan müdahale etmesi beklenir; hatta bazı organizasyonlarda bu, mühendisin birincil görevi olabilir.

- **Yapılandırma ve İnce Ayar:** Mühendis; **SIEM (Güvenlik Bilgileri ve Olay Yönetimi)**, **Güvenlik Duvarları (Firewalls)**, **WAF (Web Uygulama Güvenlik Duvarı)** ve **EDR (Uç Nokta Tespit ve Müdahale)** gibi güvenlik araçlarının kurulumundan, yapılandırılmasından ve ince ayarlarının yapılmasından sorumlu olabilir.
- **Satın Alma ve Karar Verme:** Organizasyonun ihtiyaçlarına ve mühendisin rakip ürünler üzerindeki değerlendirmelerine dayanarak, hangi araçların tedarik edileceği konusunda karar verici olabilir veya karar vericilere teknik girdi sağlar.

6.2. Masaüstü Tatbikatları (Tabletop Exercises)

Organizasyonun operasyonel hazırlık seviyesini güvenlik perspektifinden ölçmek için yapılan simülasyonlardır. Güvenlik mühendisi genellikle bu tatbikatların yürütücüsüdür.

- **Süreç:** Belirli senaryolar tanımlanır ve güvenlik ekibi üyeleri, tartışılan senaryo karşısında kendi rollerini ve yapacakları hamleleri sözlü olarak açıklar.
- **Senaryo Örneği:** Bir uç nokta (endpoint) cihazının, bir **oltalama (phishing)** e-postası yoluyla ele geçirildiği (compromise) bir senaryo ele alınır. Tüm ekip üyeleri, organizasyonun mevcut **oyun kitaplarına (playbooks)** göre atacakları adımları sırasıyla anlatır. Bu sayede teorik planların pratikteki işleyişi test edilir.

6.3. Felaket Kurtarma ve Kriz Yönetimi (Disaster Recovery and Crisis Management)

Sağlam bir güvenlik duruşu, beklenmedik olaylara, felaketlere veya krizlere karşı hazırlıklı olmayı gerektirir.

- **İş Sürekliliği Önceliği:** Herhangi bir felaket senaryosunda üst yönetimin en büyük önceliği **İş Sürekliliğini (Business Continuity)** sağlamaktır.
- **Planlama:** Güvenlik mühendisi; çeşitli uyumluluk çerçeveleri ve organizasyonun iç politikaları gereği **Felaket Kurtarma (Disaster Recovery)**, iş sürekliliği ve kriz yönetimi

planlamalarında aktif rol alır. Bu alandaki sorumluluk düzeyi organizasyona göre farklılık gösterebilir.